

Eng 1.2. Security Principles

1. Security Principles

CIA Triad

- **Confidentiality** means keeping your data secret, like making sure only the right person sees your credit card info when you're shopping online.
- **Integrity** is about keeping your data unaltered — so no one can sneak in and change your shipping address to send your package somewhere else.
- **Availability** ensures that the system is up and running when you need it — like being able to place your online order instead of staring at a "Service Unavailable" page.

DAD Triad

- **Disclosure** is the opposite of **Confidentiality**. If someone leaks your secret info, it's like breaking the "**confidentiality**" rule.
- **Alteration** is the opposite of **Integrity**. Imagine someone scribbling on a check — yep, that's a big no-no for **integrity**!
- **Destruction** (or denial) is the opposite of **Availability**. Think of it as the digital equivalent of breaking the "Open" sign on a shop's door.

Together, these attacks form the evil counterpart to the **CIA Triad**, cleverly called the **DAD Triad: *Disclosure, Alteration, and Destruction.***

Patient Records:

- **Disclosure:** If an attacker leaks medical records online, the healthcare provider takes a big hit for failing to protect **confidentiality**.
- **Alteration:** Imagine if someone changes a patient's medical record — giving them the wrong treatment could be dangerous or even life-threatening.
- **Destruction/Denial:** If an attacker shuts down the hospital's systems, no patient records are accessible, and the whole facility grinds to a halt.

Balancing security is tricky. Protecting **confidentiality** and **integrity** too much might make the system hard to use while boosting **availability** might put your secrets at risk. The key is finding that sweet spot between the three!

The attacker managed to gain access to customer records and dumped them online. What is this attack?

Disclosure

A group of attackers were able to locate both the main and the backup power supply systems and switch them off. As a result, the whole network was shut down. What is this attack?

Destruction/Denial

2. Fundamental Concepts of Security Models

1. Bell-LaPadula Model (for Confidentiality) This model is all about keeping secrets safe, using three simple rules:

- **Simple Security Property ("no read up"):** If you're at a lower security level, you can't peek at info above your clearance level. Think of it as "Sorry, that's classified!"
- **Star Security Property ("no write down"):** If you've got high clearance, you can't spill the beans to anyone below you.
- **Discretionary-Security Property:** There's a chart (access matrix) that says who can read or write to what.

Basically, you can see stuff below your level and share secrets with those above you. But, **Bell-LaPadula** *isn't great for file sharing*.

2. Biba Model (for Integrity) The **Biba model** is all about protecting data from being messed with, and it flips **Bell-LaPadula's** rules:

- **Simple Integrity Property ("no read down"):** If you're at a high **integrity** level, don't trust anything from lower levels.
- **Star Integrity Property ("no write up"):** If you're at a low **integrity** level, you can't change anything at a higher level.

The reverse of **Bell-LaPadula**. But **Biba** doesn't do well with insider threats (those sneaky co-workers!).

3. Clark-Wilson Model (for Integrity) Clark-Wilson takes *integrity* to the next level by focusing on:

- **Constrained Data Item (CDI):** *The data you want to protect.*
- **Unconstrained Data Item (UDI):** *The rest, like user input.*
- **Transformation Procedures (TPs):** *Operations that safely handle the CDIs (like read/write).*
- **Integrity Verification Procedures (IVPs):** *They check if the CDIs are still legit.*

Clark-Wilson focuses on keeping *important data clean and valid*.

There are tons of other models out there, like the Brewer and Nash or Graham-Denning models, but these three are a great starting point for thinking about security.

Click on "View Site" and answer the four questions. What is the flag that you obtained at the end?

THM{SECURITY_MODELS}

3. Defense-in-Depth

ISO/IEC 19249: the **ISO/IEC 19249** is like a rulebook made by some international pros who are super serious about security. They've come up with fancy design ideas for building secure stuff — whether it's an app, a system, or something else.

Here's a Peek Into the Five Big Ideas from their Secret Recipe:

1. **Domain Separation:** Imagine your computer as a VIP party. The cool operating system guys are in the VIP section (ring 0), and the regular apps? They're chilling in general admission (ring 3). This is like keeping your friends from crashing your boss's dinner party.
2. **Layering:** Picture your system like a big, delicious layer cake. Each layer has its own flavor (responsibility), and the security rules can be applied at different stages. Think of it like baking a cake while making sure no one adds anything weird, like hot sauce, in the middle.

3. **Encapsulation:** This is like owning a car. You don't need to know how the engine works — just use the gas pedal to go! In programming, you use specific functions (like the gas pedal) without poking around the complex stuff underneath.
4. **Redundancy:** Backup on backups! If one thing fails, the show still goes on. Like when your phone dies, but you've got a backup power bank. Or, in tech terms, if one hard drive goes kaput, the others keep your data safe.
5. **Virtualization:** One set of hardware, multiple systems — it's like having one body, but being able to control a robot army. It's also super handy for security because each "robot" (virtual machine) can be kept in its own little sandbox, so one bad apple doesn't ruin the bunch.

Now, **ISO/IEC 19249** also has **Five Design Tips** for making your system tough:

1. **Least Privilege:** *Give people just enough power to do their job — no more.* Like when your roommate asks to borrow your phone, but you make sure they can only use the calculator, not snoop in your photos.
2. **Attack Surface Minimization:** *The smaller the target, the less likely it gets hit.* So, if you don't need a service running, turn it off! It's like locking all doors in your house, except the one you actually use.
3. **Centralized Parameter Validation:** *Double-check everything!* Just like when you don't let your friends enter gibberish into your Netflix account. You centralize this so no one slips in any shady stuff.
4. **Centralized Security Services:** *Keep all your security rules in one place.* Think of it like a bouncer at the club's entrance — one person handling all the IDs instead of having someone check at every table.
5. **Preparing for Error Handling:** *Things go wrong; it's life.* But when they do, don't let the whole system crash. Plan for it! It's like having a lifeboat on a ship: when the ship sinks, you don't want to scramble, you want to have a way to stay afloat!

Which principle are you applying when you turn off an insecure server that is not critical to the business?

Your company hired a new sales representative. Which principle are they applying when they tell you to give them access only to the company products and prices?

1

While reading the code of an ATM, you noticed a huge chunk of code to handle unexpected situations such as network disconnection and power failure. Which principle are they applying?

5

4. Zero Trust versus Trust but Verify

***Trust** is one tricky business.* We can't live without it, but sometimes it makes us paranoid. Like, if you thought your laptop vendor slipped some spyware onto your machine, you'd be rebuilding your whole system in no time!

***Zero Trust** takes things a step further — it's the "**trust nobody**" rule.* It treats trust like it's some kind of dangerous bug. Instead of assuming everything's cool because the device is on your network, **Zero Trust** makes everyone and everything prove they're legit before they get in.

This approach requires **authentication** and **access control** at every turn, so even if something bad happens, it's harder for things to spiral out of control.

5. Threat versus Risk

- **Vulnerability:** This is your weak spot — like leaving the front door wide open with a "Do Not Enter" sign. In security terms, it's a flaw that makes you an easy target.
- **Threat:** Here comes the villain, thinking, "Oooh, an open door!" This is the potential danger that can exploit that weakness.
- **Risk:** Now, how likely is it that the villain walks through that open door, and if they do, what kind of mess are they going to make? That's a risk!

Picture this: You've got a showroom with fancy glass windows. The glass is **vulnerable** because, well, it's glass! The **threat** is someone with a rock who's

feeling destructive. The **risk**? How likely is someone going to smash that window, and how many dollars will you cry over if they do?

Now, in the tech world: You're working for a hospital, happily storing patient records in a database. One day, the internet drops a bombshell: your database is **vulnerable**, and hackers have got the keys to break in (**threat**). Now you're sweating as you assess the **risk** — how soon is this going to hit you, and how big will the explosion be? ***Time to act before the villains strike!***